

Module 1

This is a single, concatenated file, suitable for printing or saving as a PDF for offline viewing. Please note that some animations or images may not work.

Module 1 Study Guide and Deliverables

January 16 – January 22

Theme:	Introduction to Cybersecurity
Topics:	• Basic concepts and terminology in cybersecurity ◦ Motivation to study cybersecurity, real world examples of cyberattacks. ◦ Branches of cybersecurity ◦ Basic concepts: CIA, vulnerability, threat, risk, attack, compromise, control • Legal issues and ethics, • Risk analysis and security management
Readings:	• Chapter 1, Chapter 10, and Chapter 11
Assignments:	• Lab 1 due Tuesday, January 23 at 6:00 AM ET (Access at "Assignments" on the left-hand course menu.)
Assessments:	• Quiz 1 due Tuesday, January 23 at 6:00 AM ET (Access at "Assessments" on the left-hand course menu.)
Discussions:	• Discussion 1 posts due Tuesday, January 23 at 6:00 AM ET. Any posts after the due time will not be included in the grading process. (Access at "My Group" on the left-hand course menu.)
Live Classroom:	Join the live classroom and the facilitator's live office hour session at "Live Classroom/Offices" > "Live Classroom" > Launch Meeting. • Lecture: Tuesday, January 16, 7:30-9:00 PM ET • Facilitator office hour: TBD

■ Topic 1 Basic Concepts and Terminology in Cybersecurity

Learning Outcomes

By the end of this module, you will be able to:

- Explain basic concepts and terminology related to cybersecurity such as CIA, IAAA, privacy, etc.
- List important laws and regulations related to information security and data privacy.
- Describe basic ethical principles and issues associated with the cybersecurity profession.
- Describe basic risk assessment and management.

Why Is Cybersecurity Important?

As we are living in an interconnected digital world today, cybersecurity encompasses every aspect of our lives, both personal and professional. We have seen an upsurge in security attacks at all different levels, from the individual to the organizational to the national. Cybersecurity is crucial to ensure the successful functioning of the economy, the defense of the country, and the protection of our individual privacy. The cyberspaces that we live in are interconnected globally, spanning countries, governments, businesses, organizations, and individuals; they process, store, and communicate highly sensitive economic, financial, military, and personal information. Securing these cyberspaces is crucial to ensure the normal functioning of our daily lives.

However, it is not trivial to design and implement security systems that can also function correctly and efficiently. Increased security may make the system complex and affect its usability. A fine balance needs to be maintained between the level of insurance on one side and the efficiency and usability of the system on the other.

Cyberattacks at the National Level

James Clapper, the former Director of National Intelligence (DNI), stated that cybersecurity is a critical element of national security (CENS). Richard Clarke, former National Coordinator for Counter-Terrorism, defined cyberwar as "actions by a nation-state to penetrate another nation's computers or networks for the purposes of causing damage or disruption." Former Secretary of Defense Leon Panetta once described cyberwarfare as "the most serious threat in the twenty-first century," capable of destroying our entire infrastructure and crippling the nation.

At the national level, critical and highly valuable infrastructures are targeted, including banking and financial systems, medical systems, transportation systems, communication systems, electrical infrastructures, water resources, oil and gas systems, and government entities. Here are a few famous examples of attacks at this level:

- The 2007 cyberattacks on Estonia
- The 2008 cyberespionage targeting U.S. military computers
- The 2010 Stuxnet attacks on the Iran nuclear program
- The 2017 ransomware attack on Ukraine and on the UK national health service

Cyberattacks at the Organizational Level

Cybercrime at the organizational level is mostly concerned with financial gain. Big or small, organizations are at risk of attacks every day, causing financial loss either directly or indirectly (e.g., through damage to their reputation). The 2020 Global Threat Report by CrowdStrike shows that ransomware such as Ryuk, DoppelPaymer, REvil, Maze, and BitPaymer has drawn millions of dollars from its targets in recent years, including from local governments, school districts, manufacturing plants, media organizations, financial services, healthcare organizations, and technology companies.

In addition to high-volume ransomware attacks, other attacks at the organizational level include banking trojans, spambots, business email scams, targeted eCrime operations, carding shops, and malware-as-a-service (MaaS).

Cyberattacks at the Individual Level

Cybercriminals target not only national governments and big businesses; individuals are also their targets. As the majority of individuals are not aware of the risk, millions of potential targets are vulnerable to cyberattacks ranging from spam, to phishing attacks, identity theft due to ransomware, and other attacks. As most individuals don't have the resources to easily recover from an attack, it can be more destructive for them. Cybersecurity, like public health, is important for everyone!

Cyberwarfare, Cyberterrorism, and Cybercrime

There are several terms often used to describe cyber attacks:

- Cyberwarfare is typically referred to as the state-on-state action equivalent to an armed attack or use of force in cyberspace that may trigger a military response with a proportional kinetic use of force (Theohary & Rollins, 2015). It includes single or colluded acts to target systems for financial gain or to cause disruption. Cyberwarriors usually target an adversary's critical infrastructure, to render it unusable or un-trustable. Making the target un-trustable can result in a reluctance to use the targeted service. Preventing a target from using assets or destroying infrastructure components and assets are forms of cyberwarfare that can have devastating consequences in sensitive areas such as military applications.
- Cyberterrorism can be defined as "the premeditated use of disruptive activities, or the threat thereof, against computers and/or networks, with the intention to cause harm or further social, ideological, religious, political or similar objectives, or to intimidate any person in furtherance of such objectives." In general, a cyberterrorist will likely view the target's information and communications infrastructure as assets worth subverting, either to directly create fear/terror or as a "force multiplier" in conjunction with some other form of attack (likely physical) (Mocana, 2010). One goal of cyberterrorists is to cause an adversary (target) to fear that the cyberterrorist will inflict terror, namely kill or injure people. Another goal is to increase the adversary's (target's) willingness to submit to the demands of the attacking entity/organization, and possibly to extort financial or other assets from the target.
- Cybercrime includes unauthorized network breaches and theft of intellectual property and other data. It is usually financially motivated, and responding to it is typically the jurisdiction of law enforcement agencies.

While each type of cyberattack may have different motivations, goals, and objectives, they all use similar methods and techniques.

Stop and Research

Do some research on the internet and find a cyberattack that occurred in the last three years. Was the attack at the national level, the organization level, or the individual level? Can that attack be

considered cyberwarfare, cyberterrorism, or cybercrime?

What is Cybersecurity?

ITU ([International Telecommunication Union](#)) defines **cybersecurity** as follows:

"Cybersecurity is the collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance and technologies that can be used to protect the cyber environment and organization and user's assets. Organization and user's assets include connected computing devices, personnel, infrastructure, applications, services, telecommunications systems, and the totality of transmitted and/or stored information in the cyber environment. Cybersecurity strives to ensure the attainment and maintenance of the security properties of the organization and user's assets against relevant security risks in the cyber environment."

Cybersecurity is often used interchangeably with "information security," though there are some subtle differences between these two terms. Information security focuses on the protection of information, while cybersecurity emphasizes the protection of the whole cyber system.

The [ATIS \(Alliance for Telecommunications Industry Solutions\)](#) glossary defines **information security** as:

"The protection of information against unauthorized disclosure, transfer, modification, or destruction, whether accidental or intentional."

Additionally, computer security and network security are often used as synonyms for cybersecurity. However, they are generally considered important subsets of cybersecurity. The ATIS glossary provides the following definitions:

- Computer security: The application of hardware, firmware and software security features to a computer system in order to protect against, or prevent, the unauthorized disclosure, manipulation, deletion of information or denial of service.
- Network security: Protection of networks and their services from unauthorized modification, destruction, or disclosure. It provides assurance the network performs its critical functions correctly and there are no harmful side-effects. Web security becomes more and more popular at the application end in a networked cyberspace.

System security, database security, and web security are important subfields of computer/network security. In addition, there are several other important subfields, as well as some emerging security areas:

- Cloud security: protection of data, applications and infrastructures involved in cloud computing.
- Mobile security: protection of mobile devices, including data and applications stored on these devices.
- IoT security: protection of interconnected IoT (Internet of Things) devices, including data and applications stored on these devices.
- AI security: leveraging AI (Artificial Intelligence) techniques in cybersecurity.

Common Body of Knowledge

Cybersecurity encompasses a lot of areas and knowledge. The [International Information Systems Security Certification Consortium, Inc \(ISC\)²](#) developed a cybersecurity CBK (Common Body of Knowledge), which is a collection of relevant topics in the ever-changing field of cybersecurity. It establishes a common framework of information security terms and principles, which enables cybersecurity and IT/ICT professionals worldwide to discuss, debate, and resolve matters pertaining to the profession with a common understanding, taxonomy, and lexicon. The updated version of CBK defines the following eight domains:

- **Security and Risk Management:** topics include basic security concepts, legal issues, security policies, and risk management concepts
- **Asset Security:** topics include asset classification, privacy, and data security controls
- **Security Architecture and Engineering:** topics include security models; security architecture; vulnerabilities in web-based systems, mobile systems, and IoT systems; and cryptography
- **Communications and Network Security:** topics include network attacks and countermeasures, as well as secure network design and implementation
- **Identity and Access Management:** topics include access control, identification and authentication, and authorization
- **Security Assessment and Testing:** topics include vulnerability assessment, penetration testing, and security testing
- **Security Operations:** topics include investigation, incident management, disaster recovery, and business continuity
- **Software Development Security:** topics include secure software development models and secure coding

The CISSP (Certified Information System Security Professional) certification by (ISC)² is one of the most popular industry certificates in cybersecurity. All of the above eight domains are covered in the certification exam. You can find more information about CISSP and CBK at [The \(ISC\)² CBK](#). Here is a list of some topics covered in each domain based on their website.

Security and Risk Management	CIA (confidentiality, integrity, and availability) concepts and applications; security governance principles such as security control frameworks; due care/due diligence; organizational processes, roles, and responsibilities; legal and regulatory issues; privacy, ethics, and security policy standards, procedures, and guidelines; business continuity requirements; personnel security policies and procedures; risk management concepts; threat modeling concepts and methodologies; security education programs.
Asset Security	Asset identification and classification; data privacy; asset retention; data security controls; asset handling requirements.
Security Architecture and Engineering	Security processes; security design principles; security models; security controls; security capabilities systems; vulnerabilities assessments and mitigation in different systems such as web-based systems, mobile systems, and embedded systems; applied cryptography; site and facility security design and controls.
Communication and Network Security	Security design in network architectures; secure network components including hardware operations; transmission media; network access control devices; endpoint security; content-distribution networks; secure communication channel implementation.
Identity and Access	Control of physical and logical access to assets; identification and authentication management;

Management (IAM)	third-party services; authorization management; access provision lifecycles.
Security Assessment and Testing	Assessment tests and audit strategies; security control testing such as vulnerabilities assessments; penetration testing; test coverage analysis; security assessment data collection and analysis; security audits.
Security Operations	Digital forensics and investigation; logging and monitoring activities; foundational security operations concepts; resource protection techniques; configuration management and change management; incident management; disaster recovery and business continuity; physical security; personnel security.
Software Development Security	Secure software development lifecycles; security control in development environments; secure coding guidelines and standards.

In this course, we will discuss basic security concepts, models, and principles, provide a brief overview of each domain, and discuss the Security Architecture and Engineering and Identity and Access Management domains in more details.

Specifically, we will cover the following topics:

- Basic terminology
- Legal and ethical issues
- Risk analysis and management
- Common vulnerabilities
- Cryptography
- Authentication and authorization
- Network security and web security
- Operating system security and hardware security
- Mobile and IoT security

In addition to this course, our security program offers a number of courses that cover all these domains in great detail. CS684 discusses the Risk Management and Asset Security domains in detail. CS690 focuses on the Communication and Network Security domain, and CS763 focuses on the Security Assessment and Testing and Software Development Security domains. We also offer several digital forensics courses such as CS693 and CS694, covering the Security Operations domain.

Cybersecurity Work Roles in the NICE Framework

The National Initiative for Cybersecurity Education (NICE) Cybersecurity Workforce Framework (NICE Framework), [NIST Special Publication 800-181](#), is a national resource that categorizes and describes cybersecurity work. The NICE Framework establishes a taxonomy and common lexicon that describes cybersecurity work and workers in all public, private, and academic sectors. The current framework defines several categories, each containing a group of specialty areas. Additionally, it defines work roles in each area and the KSAs (Knowledge, Skills, and Abilities) required to perform each work role. The seven categories are:

- Securely Provision (SP) conceptualizes, designs, procures, and/or builds secure information technology (IT) systems, with responsibility for aspects of system and/or network development.
- Operate and Maintain (OM) provides the support, administration, and maintenance necessary to ensure effective and efficient information technology (IT) system performance and security.
- Oversee and Govern (OV) provides leadership, management, direction, or development and advocacy so the organization may effectively conduct cybersecurity work.
- Protect and Defend (PR) identifies, analyzes, and mitigates threats to internal information technology (IT) systems and/or networks.
- Analyze (AN) performs highly-specialized review and evaluation of incoming cybersecurity information to determine its usefulness for intelligence.
- Collect and Operate (CO) provides specialized denial and deception operations and collection of cybersecurity information that may be used to develop intelligence.
- Investigate (IN) investigates cybersecurity events or crimes related to information technology (IT) systems, networks, and digital evidence.

The framework also provides the keyword search functionality at [NICE Framework Work Roles](#).

Stop and Research

What aspects/topics/jobs in cybersecurity interests you most? Choose a few keywords, and search for the relevant work roles, knowledge, skills, and abilities in the NICE framework.

Basic Security Terminology (CIA, IAAA, Privacy)

The **CIA** acronym, which stands for confidentiality, integrity, and availability, is the most common term used in cybersecurity. The CIA acronym also represents the fundamental security concepts and security goals. In this course, we will provide students with a deeper understanding of security's fundamental concepts and the application of these concepts.

- **Confidentiality** is concerned with ensuring that knowledge about a unit of information, and access to that information, is provided only to individuals who have some right (authorization) to know about or access the information. For example, students can only see their own grades in Blackboard, not others' grades.
- **Integrity** is concerned with the accuracy of information, or its functionality, either from the perspective of detecting unauthorized changes or ensuring that only allowed changes to information or functionality occur. For example, only the instructor (or the grader) can modify students' grades. No other people, including the students themselves, can modify the grade.
- **Availability** is concerned with ensuring that information or functionality can be accessed or used by those who have a legitimate right to access or use it. For example, every student should be able to access the course material on Blackboard.



When considering CIA, we need to consider how to prevent unauthorized access as well as how to ensure proper access when authorized. In support of the CIA concepts, another acronym, **IAAA**, which stands for the following, is also commonly used:

- **Identification** is concerned with asserting who a person is. It is typically public or well-known. For example, your BU ID is your identification to access Blackboard.
- **Authentication** is concerned with verifying that the asserted identity of an individual who wants access to information or service functionality is authentic. It should be private. Usually, passwords are used as a type of secrecy for authentication. Multi-factor authentication also uses other factors besides passwords, such as SMS-based one-time codes sent to the user's mobile device.
- **Authorization** is concerned with controlling what information or functionality authenticated individuals can access. Who can access what needs to be clearly defined, so that we know whether an access is authorized or unauthorized.
- **Accounting** (sometimes also referred as *Audit*) is concerned with knowing who has accessed a piece of information or used some functional capability or service. Logging is often used to record every action so that it is accounted for.

Through IAAA, nonrepudiation is also achieved. **Nonrepudiation** is the assurance that someone cannot deny something that has occurred. Ensuring the authenticity of the log is also critical to ensure nonrepudiation.

The main task of IAAA is proper access control. IAAA is often provided by a dedicated server to perform access control. Access control defines what/how each subject (class) is allowed to interact with which objects, where

- Subjects: are users, administrators, operators, technicians, and software
- Objects: are resources such as files, data, and computers

The basic principle for access control is the **Principle of Least Privilege**, which provides access to only what is necessary.

How can one specify and ensure proper access control? There are several different **access control models**:

- DAC (Discretionary Access Control): restricts the access to objects based on the identity of subjects and/or groups to which they belong. Typically, the owner of the object can change the permission at their discretion.
- MAC (Mandatory Access Control): usually includes OS controls and changes the ability of a subject to access an object.

- RBAC (Role-based Access Control): restricts the access to objects based on the role a subject is assigned to.

Privacy is another hot term in information security that has become more and more important. Privacy is defined as “the quality or state of being apart from company or observation, seclusion, freedom from unauthorized intrusion (one’s right to *privacy*)” (Webster’s New Collegiate Dictionary, Merriam Webster, 1981). Sometimes, the term is used interchangeably with confidentiality. However, privacy is different from confidentiality. Based on NISTIR 4734, privacy is the right of a party to maintain *control over the confidentiality of information about itself*. Privacy is mostly associated with accessing (reading) *personal information*, which is any information that can be used to identify or contact an individual or can be reasonably linked to a specific individual, device, or computer. Privacy is concerned with the proper handling of data, including consent, notice, and regulatory obligations. This includes *whether or how data is shared with third parties, and how data is legally collected or stored*.

The need for information privacy varies by context, i.e.:

- A customer will allow a cashier to know the customer’s credit card number when making a purchase but does not want other people to know the number.
- A patient will record their U.S. Social Security number on a form at the doctor’s office or hospital but will expect staff members to protect it.
- A consumer subscribed to a location-enabled service will gladly allow the service provider to track the consumer’s location to provide location proximity-based services but does not want to otherwise be tracked except for in an emergency situation.

Privacy involves varying degrees of confidentiality of, or access control over, specific information about the customer/service consumer. It should be recognized as an issue of authorization rights to different objects, regardless of the unique form.

There are several regulations related to data privacy, such as GDPR (General Data Protection Regulation) adopted by the European Union, HIPAA (Health Insurance Portability and Accountability Act) for the healthcare sector, GLBA (Gramm-Leach-Bliley Act) for the financial sector, and CCPA (California Consumer Privacy Act).

Other Security Terminology

We have to understand that it is impossible to achieve perfect security. We need to also balance security and other aspects, such as usability, efficiency, etc. Bad things can always happen. Before we dive into more details, let us introduce a few more security terms such as security incident, vulnerability, threat, exploit, attack, and risk. We use the [NIST definition](#) for most of the terms.

- Incident: an incident is an occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use policies. It may be caused by a natural disaster, incidental human actions, or hostile actions. For example, an incident occurs if a system administrator deletes all user data by accident.
- Vulnerability: a vulnerability is a weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.
- Threat: a threat is any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information,

and/or denial of service. It may also refer to the potential for a threat source to successfully exploit a particular information system vulnerability. Threat sources includes spyware, malware, adware, worms, viruses, and attackers.

- **Exploit:** an exploit is a tool or method by which an attacker uses a vulnerability to cause damage to the target.
- **Attack:** an attack is any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself. It usually occurs when a threat source attempts to exploit a vulnerability. A compromise occurs when an attack is successful. It is typically associated with taking over/altering resources.
- **Risk:** risk is the level of impact on organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals resulting from the operation of an information system given the potential impact of a threat and the likelihood of that threat occurring. A risk factor has two characteristics: possibility and damage. Risk analysis includes identifying risks and their impact and creating a plan to mitigate risks and impacts. The goal is to minimize the risk by minimizing the vulnerabilities and blocking threats.
- **Security control:** a security control is a countermeasure. It may be an action, a device, a procedure, or a technique that can help block attacks. We need to understand that there is no silver bullet to prevent attacks. Defense in Depth—a strategy that integrates people, technology, and operations across an organization to provide variable measures of protection—is a very important principle. Security controls need to be implemented at multiple layers with various tools/mechanisms/techniques, so that if one fails, another is still in place.

Example

Consider the following scenario: suppose the course instructor keeps everyone's grade on his/her laptop with a screen lock that starts after one hour of idle time. The instructor goes out of the office for lunch without closing the door, leaving the laptop on the desk. Identify the possible vulnerability, attacker, threat, attack, compromise, and security control.

We will discuss different types of vulnerabilities, threats, attacks, and various security controls in more detail in the next Module.

Test Yourself

CIA stands for _____, _____, and _____.

Confidentiality, Integrity, Availability

Test Yourself

IAAA stands for _____, _____, _____ and _____.

Identification, Authentication, Authorization, Accounting (or Audit)

Test Yourself

Provide an example where nonrepudiation (e.g., nonrepudiation of sender, nonrepudiation of receipt, or nonrepudiation of actions) is needed to ensure information security. Briefly describe how it can be

achieved.

Test Yourself

DAC stands for _____. MAC stands for _____. What are their differences?

DAC stands for Discretionary Access Control, and MAC stands for Mandatory Access Control. DAC is distributed control, usually determined by the owner of the object. MAC is centralized control, usually determined by the system (e.g. OS). MAC is usually more secure than DAC.

Test Yourself

Use your home network as an example to provide examples of the following terms: subject, object, vulnerability, threat, attack, risk, and security control.

■ Topic 2 Legal and Ethics Issues

Law and Regulations

While technology is essential to cybersecurity, the legal and ethical aspects are equally important.

Cybersecurity is both strengthened and constrained by applicable laws. Laws protect as well as regulate people in cyberspace. However, the law can barely keep up with technology. Some existing legal protections, such as copyright, privacy, and privacy, can be applied to computer-related issues, though they may not deal well with digital or virtual technology. There are still many areas in cybersecurity that lack proper regulation and control. As cybersecurity professionals, we must not only understand the current state of cybersecurity related law, but also help change the old laws and develop new ones.

First, let us understand the differences between different types of law.

- Criminal law contains statutes that state explicitly that certain wrongful actions are illegal and harm the desired nature of society. The consequences of breaking criminal law are usually jail time or fines.
- Civil law does not require as high a standard of proof of guilt as criminal law. A civil case usually involves wrongful actions that cause harm to individuals or corporations. The remedy is usually compensation to the victim.
- Common law is the body of law derived from judicial decisions, rather than from statutes or constitutions. It is practiced in the United States, Canada, the United Kingdom, and many other places. The most significant difference from civil law is that in civil law, judicial precedents and particular case rulings do not have the same weight as they do under common law.
- Tort law involves torts, which in common law jurisdiction, are civil wrongs that cause a claimant to suffer loss or harm, resulting in legal liability for the person who commits a tortious act. It can include the intentional infliction of emotional distress, negligence, financial losses, injuries, invasion of privacy, and many other things.

To properly apply the law, we need to know which jurisdiction has the legal authority to set rules. It is not enough to know the relevant geography or political boundaries. Jurisdiction may be established based on the activity of the organization and influenced by international treaties, agreements, or any number of other factors.

Most cybersecurity-related laws currently provide protections in the following areas:

- Cybercrime
- Intellectual property
- The rights of programmers and of their employers
- Users (consumer rights, liability, etc)

Cybercrime

Cybercrimes include criminal offenses committed via the internet or otherwise aided by various forms of computer technology. Cyber systems can be used as a means to commit traditional crimes such as fraud, extortion, pornography, cyberbullying, sexting, or identity theft, or can be the target of crime themselves, as in the case of denial-of-service (DoS) attacks, data breaches, cyber-intrusions, etc.

As existing criminal laws are mostly restricted to theft of tangible (i.e., physical) objects, it is very challenging to deal with digital assets or evidence. For example, it is harder to define what should be considered as crimes. It is harder to follow rules of evidence in crime investigation and persecution, as the data can be easily copied and modified. It is harder to establish a “chain of custody.” It is also harder to establish the value of loss.

Here are several U.S. laws related to cyber crimes:

- U.S. Computer Fraud and Abuse Act, 1984: prohibits unauthorized access to cyber systems and data as well as computer fraud.
- U.S. Economic Espionage Act, 1996: deals with industrial espionage (i.e., the theft or misappropriation of a trade secret and the National Information Infrastructure Protection Act) and four other areas of action that Congress deemed appropriate including the U.S. Sentencing Commission reports regarding encryption or scrambling technology, and other technical and minor amendments.
- U.S. Electronic Communication Privacy Act (ECPA), 1986: prevents unauthorized government access to private electronic communications during the evidence collection process. It extends government restrictions on wiretaps from telephone calls to include transmissions of electronic data by computer. Title I of the ECPA protects wire, oral, and electronic communications while in transit. Title II of the ECPA, the Stored Communications Act (SCA), protects communications held in electronic storage, most notably messages stored on computers. Title III prohibits the use of trace devices to record dialing, routing, addressing, and signaling information used in the process of transmitting wire or electronic communications without a court order.

Intellectual Property

Intellectual property can be protected through copyright, patents, or trade secrets. The following table from the textbook (Pfleeger, et. al. 2015) compares these three.

	Copyright	Patent	Trade Secret
Protects	Expression of an idea, not the idea	Invention - how it works	<i>Secret</i> that gives an advantage
Public disclosure at application	Promotes publication	Design must be filed at patent office	No
Requirement to distribute?	Yes	No	No
Ease of filing	Very easy	Very complicated	No filing required
Duration	Life of author + 70 years	19 years	Indefinite
Legal protection	Lawsuit for violation	Lawsuit for EVERY violation	Lawsuit for violation

The U.S. Constitution provides protections for the authorship of intellectual property, defined as the following: “original works of authorship fixed in any tangible medium of expression ... from which they can be perceived, reproduced or otherwise communicated, either directly or with the aid of a machine or device...”

Copyrights protect the “expression of idea,” not the idea itself. For example, the copyright of the textbook we use protects how the authors describe security concepts such as encryption to readers, but doesn’t protect the idea of encryption itself. Copyright specifically addresses digital media including videos, music, code, and data, as they are very easily copied.

As with copyright, you can’t patent an idea, a law of nature, an obvious method, or a well-known technique. Unlike copyright, patents protect inventions, manufacturing methods, or ways to make things. Patents are intended to apply to the results of science, technology, and engineering. Effective from March 16th, 2013, U.S. transitions from a first-to-invent system to a first-inventor-to-file system, giving priority to the applicant who first files the patent application, instead of the one who first created the invention.”

Unlike copyright holders, patent holders must actively protect patents from infringement. Copyright holders can choose which cases to prosecute, ignoring smaller cases, but patent holders have to sue all infringers, and the prosecution can be expensive.

Unlike a copyright or a patent, a trade secret must be kept a secret. Once divulged, it usually cannot be made secret again. If someone else happens to discover the secret independently, there is no infringement and trade secret rights are gone.

Let us use computer software as an example. Trade secret protection can be applied to software source code. While the executable programs are distributed, the source code can be kept secret. Trade secret protects the code or algorithms used in the software from being used in another software. However, the trade secret may be easily discovered through reverse engineering. Decompilers may easily produce the source code from the executables. Various obfuscation techniques have been proposed to prevent reverse engineering.

To avoid secret discovery through reverse engineering, source code can be protected by a patent as long as the developer can prove that the underlying design is novel. The source code and the executables may also be protected under copyright.

However, this only applies to the reproduction of the code. Trade secrets are not protected if the same algorithms are re-implemented or the code is rewritten.

Copyleft and Permissive Licenses

Copyleft licenses and some other permissive licenses are often used by open-source software to promote collaboration and sharing among the developers. These licenses grant users the right to copy, modify, and distribute the source code to the community. These licenses are under the same legal framework as copyright.

Copyleft licenses, which require all derivative works to be subject to the original copyleft license, are stricter than some other permissive licenses. That means the source code of any derivative works must also be released freely and must comply with the original licensing terms. As such, developers cannot redistribute a modified derivative work under a proprietary license. The most popular copyleft license is the General Public License (GPL). Developers should be mindful not to use this type of copyleft license if they have their own proprietary codes that they do not want to share with the public.

Other free-software licenses such as MIT, Apache, and BSD are permissive licenses with much fewer requirements on the software's use, modification, and redistribution. For example, the MIT license states that the software is provided "as is" and that copyright holders will not be held liable for any claims or liabilities. The holders of the MIT license can produce, without restrictions, any derivative works from the original software and even reap commercial benefits from the sale of the derivative works.

Here are some laws related to intellectual property:

- Digital Millennium Copyright Act (DMCA), 1998: an updated version of the U.S. Copyright Law of 1978, specifically intended to deal with computers and other electronic media such as digital video and music.
- The American Inventors Protection Act (AIPA), 1999: significant updates to the American Patent Law.

Privacy

Privacy issues existed long before digital techniques and cyberspaces. However, recent advances in information technology changed the scale and speed of how personal information is stored and transmitted. Control of personal data has been reduced dramatically, and privacy has become more important than ever.

The right to privacy depends on several variables. Law and ethics set the baseline for, and enforce expectations of, privacy. Economics can determine how much privacy we are able and willing to provide.

Privacy is related to confidentiality. It can be considered an aspect of confidentiality, focusing on the control of access to personal sensitive data.

PII (Personal Identifiable Information) is usually any data that is related to an identifiable individual and can be considered sensitive data. Any information that can be used to distinguish one person from another and can be used for deanonymizing previously anonymous data can be considered PII. This includes names, addresses, phone numbers, biometrics, credit ratings, tax info, criminal records, health records, social media posts, digital images, etc.

Privacy is controlled disclosure, in that the subject chooses what personal data to give out, when, and to whom.

Privacy Laws

Below are some key laws related to privacy:

- U.S. Privacy Act, 1974: This act establishes a code of fair information practices that governs the collection, maintenance, use, and dissemination of information about individuals that is maintained in systems of records by federal agencies.
- FTC Act (The Federal Trade Commission Act): This act gives the FTC authority to ensure that companies implement appropriate privacy protections for personally identifiable information and comply with posted privacy policies and holds companies accountable for unauthorized disclosures of personal data.
- CIPA/FERPA (Family Educational Rights and Privacy Act) (Education): This is a federal law that protects the privacy of a student's educational records. The law applies to all schools that receive funds from the U.S. Department of Education. FERPA gives parents certain rights with respect to their children's education records.
- FISMA (Federal Information Security Management Act of 2002) (Government): This act requires each federal agency to develop, document, and implement an agency-wide program to provide information security for the information and systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other sources.
- SOX (Sarbanes Oxley Act, also known as The Public Company Accounting Reform and Investor Protection Act), 2002: This act aims to protect investors from fraudulent financial reporting by corporations. It mandates strict reforms to existing securities regulations and imposes tough new penalties on lawbreakers.
- HIPAA (The Health Insurance Portability and Accountability Act), 1996: This act protects sensitive patient health information from being disclosed without the patient's consent or knowledge.
- GLBA (The Financial Services Modernization Act, also known as the Gramm-Leach-Bliley Act) (Bank/Insurance): The GLBA regulates how financial service organizations use and protect financial information. Banks, securities firms, insurance companies, and other businesses that provide financial services and products must provide notice of their privacy practices and give data subjects the opportunity to opt out of having their information shared with third parties. The GLBA also addresses the disclosure of nonpublic personal information. In addition to the GLBA, financial services organizations are subject to certain FTC rules relating to the disposal and destruction of financial information.
- PCI-DSS (Payment Card Industry Data Security Standard) (Retail): This sets a global standard to protect consumer privacy

Cybersecurity Ethics

As information-related technology increasingly shapes our lives, technology ethics is of growing importance to us, regardless of our specific practice area.

Ethics deal with what is good and bad and with moral duty and obligation.

There are no absolute or universal sets of standards. Rather, ethical standards depend on culture, history, religion, time, place, etc. While certain standards of ethical behavior may be promoted by groups or organizations, each individual may develop a personal set of ethical practices.

Ethics are different from law. Ethics are personal, while laws are interpreted by courts and apply to all within the jurisdiction. The following table from the textbook summarizes their differences:

Law	Ethics
Defined by formal, written documents	Described by unwritten principles
Interpreted by courts	Interpreted by each individual
Established by legislatures representing all people	Presented by philosophers, religions, professional groups
Applied to everyone	Chosen personally
Priority determined by courts if two laws conflict	Priority determined by an individual if two principles conflict
"Right" arbitrated finally by courts	Not arbitrated externally
Enforced by police and courts	Enforced by intangibles such as principles and beliefs

The Ten Commandments of Computer Ethics

The Ten Commandments of Computer Ethics were created in 1992 by the Computer Ethics Institute in the paper "In Pursuit of a 'Ten Commandments' for Computer Ethics" by Ramon C. Barquin as a means to create "a set of standards to guide and instruct people in the ethical use of computers."

The Ten Commandments of Computer Ethics

1. Thou shalt not use a computer to harm other people.
2. Thou shalt not interfere with other people's computer work.
3. Thou shalt not snoop around in other people's computer files.
4. Thou shalt not use a computer to steal.
5. Thou shalt not use a computer to bear false witness.
6. Thou shalt not copy or use proprietary software for which you have not paid.
7. Thou shalt not use other people's computer resources without authorization or proper compensation.
8. Thou shalt not appropriate other people's intellectual output.
9. Thou shalt think about the social consequences of the program you are writing or the system you are designing.
10. Thou shalt always use a computer in ways that insure consideration and respect for your fellow humans.

These commandments are often formulated as formal codes or standards to which all members in a professional environment are held.

The ACM Code of Ethics and Professional Conduct

The Association for Computing Machinery (ACM) Code of Ethics and Professional Conduct is designed to inspire and guide the ethical conduct of all computing professionals, including current and aspiring practitioners, instructors, students, influencers, and anyone who uses computing technology in an impactful way.

The ACM Code of Ethics and Professional Conduct

1. GENERAL ETHICAL PRINCIPLES.

- 1.1 Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing.
- 1.2 Avoid harm.
- 1.3 Be honest and trustworthy.
- 1.4 Be fair and take action not to discriminate.
- 1.5 Respect the work required to produce new ideas, inventions, creative works, and computing artifacts.
- 1.6 Respect privacy.
- 1.7 Honor confidentiality.

2. PROFESSIONAL RESPONSIBILITIES.

- 2.1 Strive to achieve high quality in both the processes and products of professional work.
- 2.2 Maintain high standards of professional competence, conduct, and ethical practice.
- 2.3 Know and respect existing rules pertaining to professional work.
- 2.4 Accept and provide appropriate professional review.
- 2.5 Give comprehensive and thorough evaluations of computer systems and their impacts, including analysis of possible risks.
- 2.6 Perform work only in areas of competence.
- 2.7 Foster public awareness and understanding of computing, related technologies, and their consequences.
- 2.8 Access computing and communication resources only when authorized or when compelled by the public good.
- 2.9 Design and implement systems that are robustly and useably secure.

3. PROFESSIONAL LEADERSHIP PRINCIPLES.

- 3.1 Ensure that the public good is the central concern during all professional computing work.
- 3.2 Articulate, encourage acceptance of, and evaluate fulfillment of social responsibilities by members of the organization or group.
- 3.3 Manage personnel and resources to enhance the quality of working life.
- 3.4 Articulate, apply, and support policies and processes that reflect the principles of the Code.
- 3.5 Create opportunities for members of the organization or group to grow as professionals.
- 3.6 Use care when modifying or retiring systems.

3.7 Recognize and take special care of systems that become integrated into the infrastructure of society.

4. COMPLIANCE WITH THE CODE.

4.1 Uphold, promote, and respect the principles of the Code.

4.2 Treat violations of the Code as inconsistent with membership in the ACM.

IEEE Ethics Community

The [Institute of Electrical and Electronics Engineers \(IEEE\) has a separate division](#) devoted to technology ethics, focusing on ethical and societal impacts of technologies themselves. In addition, it has a CyberEthics and CyberPeace community on [IEEE Collabratec™](#) to specifically discuss CyberEthics and CyberPeace concepts and guidelines developed in joint activity among professionals, government, and the interested public.

Below are the codes of ethics formulated by several reputable cybersecurity organizations. However, keep in mind that there is no single set of ethical rules, guidelines, or insights that can provide guidance in all cybersecurity circumstances, nor is there any real mechanism for enforcement.

ASIS Code of Ethics

- A member shall perform professional duties in accordance with the law and the highest moral principles.
- A member shall observe the precepts of truthfulness, honesty, and integrity.
- A member shall be faithful and diligent in discharging professional responsibilities.
- A member shall be competent in discharging professional responsibilities.
- A member shall safeguard confidential information and exercise due care to prevent its improper disclosure.
- A member shall not maliciously injure the professional reputation or practice of colleagues, clients, or employers.

(ISC)² (International Information System Security Certification Consortium) Code of Ethics Canons

- Protect society, the common good, necessary public trust and confidence, and the infrastructure.
- Act honorably, honestly, justly, responsibly, and legally.
- Provide diligent and competent service to principals.
- Advance and protect the profession.

ISSA (Information Systems Security Association) Code of Ethics

- Perform all professional activities and duties in accordance with all applicable laws and the highest ethical principles;

- Promote generally accepted information security current best practices and standards;
- Maintain appropriate confidentiality of proprietary or otherwise sensitive information encountered in the course of professional activities;
- Discharge professional responsibilities with diligence and honesty;
- Refrain from any activities which might constitute a conflict of interest or otherwise damage the reputation of or is detrimental to employers, the information security profession, or the Association; and
- Not intentionally injure or impugn the professional reputation or practice of colleagues, clients, or employers.

SANS IT Code of Ethics

- I will strive to know myself and be honest about my capability.
- I will conduct my business in a manner that assures the IT profession is considered one of integrity and professionalism.
- I will respect privacy and confidentiality.

Common misconducts in cybersecurity include:

- Misrepresentation of certifications, skills, services, or products, for example:
 - Consultants who profess to offer information security consulting, but offer profoundly bad advice
 - Educators, both individuals and companies, that offer to teach information security, but provide misinformation (generally through ignorance, not intent)
 - Security Vendors, who oversell the security of their products
 - Analysts, who oversimplify security challenges, and try to upsell additional services to naïve clients
 - Legislators, who push through "from-the-hip" regulations, without thoughtful consideration of their long-term impact
- Abuse of privileges
- Inappropriate monitoring
- Withholding information
- Divulging information inappropriately
- Overstating issues
- Conflicts of interest
- Management/employee/client issues

Test Yourself

Match the law in the left column with the description in the right column.

Laws	Description
ECPA 	a. Protect patient health information
DMCA 	b. Protect student's education records
HIPPA 	c. Protect investors from fraudulent financial reporting by
CIPA/FERPA 	d. Prevent unauthorized government access to private ele during the evidence collection process.
PCI-DSS 	e. Protect consumer privacy
GLBA 	f. Regulate financial services and protect financial informa
FISMA 	g. Deal with the copyright of digital media
SOX 	h. Protect information maintained by the federal agency

Check Answers

Test Yourself

_____ protects the source code of a piece of software from being known by others; _____ prevents unauthorized distribution of a piece of software; _____ protects the key algorithms used in a piece of software from being used by others.

(Put in the correct order)

a. Copyright b. Patent c. Trade secret

C, B, A

Test Yourself

Which of the following are common in codes of ethics for cybersecurity professionals? (Check all that are true.)

Act honestly

This is true.

Be diligent and responsible

This is true.

Seek public interest

This is true.

Respect privacy

This is true.

Honor confidentiality

This is true.

Avoid harm

This is true.

■ Topic 3 Security Management and Risk Management

Introduction

In this section, we will briefly introduce security management. Without proper management, even the best technology available may not be adopted. Security awareness is the first important step. Every organization that involves data in cyberspace should have thorough and effective security planning and management.

Security Planning

A security plan is a document that describes how an organization will address its security needs. It should include both a description of the current security practices and a map for improvement. The following issues are usually addressed in a security plan:

- Policy: stating the security needs and priorities of the organization. It is a high level statement of purpose and intent. It should clearly state security goals and priorities, the responsibility and commitment of the organization. For example, here is [Boston University's Information Security Policy](#).
- Current State: including current security practices used, current vulnerabilities identified. A risk analysis is needed to assess the current security status.
- Security requirements: including functional or non-functional requirements to ensure a desired level of security. The requirements are derived from both internal needs and outside compliances. Usually, requirements are detailed illustrations of the policy imposed.
- Recommended controls: describing the security controls needed to meet the security requirements and defeat the identified vulnerabilities. The risk analysis is used to create a map from vulnerabilities to controls.
- Accountability: identifying who is responsible for fulfilling the security requirements.
- Timetable: showing how and when the elements of the plan will be performed, including milestones, the order of controls to be implemented, and a procedure for change and growth.
- Maintenance: specifying a structure for periodical review and updates.

For more details about the security plan, please read the textbook Ch. 10.1 (Pfleeger et al., 2015).

A dedicated security team is often required to develop the security plan and manage the security program. This usually involves a committee with multiple members who represent various aspects of computer security such as hardware groups, system administrators, system programmers, application programmers, data entry personnel, physical security personnel, and representative users.

Policies vs. Standards vs. Guidelines

Policies provide high-level guidance, standards tell people what is expected, and guidelines provide specific advice on how to accomplish a given task or activity.

Risk Analysis

Risk analysis is critical to security planning and management. A risk is a potential problem that can cause loss. It involves the following aspects:

- A loss associated with an event
- The likelihood that the event will occur
- The degree to which we can change the outcome

Risk management is the methodological process of identifying risks, analyzing the extent of damage that can be caused by these risks and determining how to mitigate (reduce) risks. Here are keys steps in risk management:

- Identify assets
- Determine vulnerabilities
- Estimate likelihood of exploitation
- Compute expected annual loss
- Survey applicable controls and their costs
- Project annual savings of control

Identify Assets

In this step, we need to identify what we need to protect; assets can be tangible or intangible. Valuable assets include not only things related to computer systems such as hardware, software, networks, and data, but also other things such as buildings, supplies, printed documents, and even people. In addition, intangible assets such as reputation and business continuity are important assets to protect. It is very important to compile an inventory of assets and identify essential assets in particular.

Determine Vulnerabilities/threats

In this step, we need to determine vulnerabilities in identified assets. Various techniques can be used to find possible vulnerabilities in an organized way. For example, we can identify if any vulnerabilities in assets cause the compromise of the CIA goals. **STRIDE** is a popular thread modeling tool developed by Microsoft. It defines security threats in six categories: spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege. Vulnerabilities can be identified from previous risk analysis documents, IT system audits and logs, or against various vulnerability lists. Security advisories and vendor advisories can help identify vulnerabilities as well. Some automated scanning tools can also help identify some simple and classical vulnerabilities in software systems. Penetration testing is another way to help perform vulnerability assessment. We will discuss vulnerabilities and threats in more detail in the next Module.

Estimate Likelihood of Exploitation

To quantify the effect of a risk, we need to first estimate the likelihood of exploitation, that is how often a vulnerability is likely to be exploited. Often, the probable frequency is used to estimate the likelihood based on some previously observed data or a general estimation by experts. The frequency may range from once a day to once a month to once a year. Sometimes, it is difficult to give an accurate estimation of the probable frequency; in these cases, we can simply use different scales to represent the likelihood such as 5 for “highly likely” and 1 for “highly improbable.”

Compute Expected Annual Loss

To quantify the effect of a risk, we also need to determine the likely loss upon successful exploitation. Some losses are easy to compute, such as the cost to replace hardware items, supplies, or a piece of software. But others may not be easy to

compute. For example, it is harder to determine the legal fees if sensitive data gets leaked. It will be even harder to estimate loss of reputation damage due to a down service or data breach.

Survey Applicable Controls and Their Costs

To address identified risks, we need to find proper security control. We want to match each vulnerability with at least one appropriate security technique. More often, multiple security controls need to be in place. **Defense in Depth** is a very important principle. For example, the username and password pair is commonly used to prevent unauthorized access. Multi-factor authentication addresses the issue of a weak password. On the other hand, some security techniques can address multiple security issues, such as data encryption, which protects both confidentiality and integrity.

Each security control may have its own pros and cons. For example, long complex passwords provide better protection, but are harder for users to remember. Touch IDs are much easier to use, but may not be stable. In general, there is no single best set of controls. One can use the graph theory to select a minimal set of controls that address all vulnerabilities. When there are overwhelming risks and controls, it is also important to prioritize the risks and address higher priority risks.

Project Annual Saving of Control

To quantify the effects of a risk, we can calculate the risk exposure as the product of risk impact and risk probability. More formally, we have

$$ALE = SLE \times ARO$$

where SLE is single loss expense, ARO is annual rate of occurrence, and ALE is annual loss expense. We can also calculate SLE as

$$SLE = AV \times EF$$

where AV is asset value and EF is exposure factor.

We can also calculate risk leverage as an indicator for different sets of control using the following formula:

$$\text{Risk leverage} = \frac{\text{risk exposure before reduction} - \text{risk exposure after reduction}}{\text{cost of risk reduction}}$$

Depending on the quantitative analysis result, different strategies may be used to deal with risks, including:

- Risk avoidance: eliminate the possibility of risk by avoiding engaging in activities that create exposure to risk.
- Risk transference: transfer risks to a third party. For example, purchasing insurance is a common example of transferring risk from an individual or entity to an insurance company.
- Risk mitigation: reduce the risk impact by applying countermeasures. This is the most common strategy.
- Risk acceptance: simply accept the risk if the cost of addressing the risk is higher than the savings.

Be aware that many tasks in risk analysis are not trivial and may lack accuracy. However, risk analysis is a well-known tool for security planning and management. It is very helpful to improve security awareness, weigh the trade-offs, and justify the spending for security.

Standardization Organizations

There are organizations that define security standards or make security recommendations.

- International
 - [ISO \(International Organization for Standardization\)](#): develops and publishes international standards, including
 - ISO/IEC 27001 — Information security management
 - ISO 9000 FAMILY — Quality management
 - OSI (Open Systems Interconnection) model
 - ISO Standard 27001-2005.pdf
 - [ITU-T \(International Telecommunication Union Telecommunication Standardization\)](#): develops and publishes international standards for telecommunications equipment and systems known as ITU-T recommendations, including
 - ITU-T Recommendation M.3410-prepublication.pdf
 - ITU-T Recommendation X0200.pdf
 - ITU-T Recommendation X0700E.pdf
 - X.509
- National
 - [ANSI \(American National Standard Institute\)](#): supports the U.S. voluntary standards and conformity assessment system
 - ANSI Standard T1.276-2003 OAMP Security.pdf
 - [ATIS \(Alliance for Telecommunications Industry Solutions\)](#): develops technical and operational standards and solutions for the ICT, accredited by ANSI
 - [ETSI \(European Telecommunications Standards Institute\)](#): develops standards in the information and communications technology industry fulfilling European and global market needs
 - [TIA \(Telecommunications Industry Association\)](#): accredited by ANSI to develop voluntary, consensus-based industry standards for Information and Communication Technologies (ICT) products
- Industry/Technology SDOs
 - [IETF \(Internet Engineering Task Force\)](#): a large, open international community of network designers, operators, vendors, and researchers concerned with the evolution of internet architecture and the smooth operation of the internet
 - OIF, ATMF, TMF, MSF, VoIPSA, IETF, OMG, ...
- U.S. Government
 - [NIST \(National Institute of Standard and Technology\)](#):
 - NIST Common Criteria (2 of 3 parts)
 - NIST Standard rbacSTD-ACM.pdf
 - [DoD \(Department of Defense\)](#)
 - DoD 5200.28-STD.pdf
 - [NASA \(National Aeronautics and Space Administration\)](#)
 - DHS National Infrastructure Protection Plan (NIPP) and sector specific plans (agriculture/food, banking, comm., defense industry, energy, IT, transportation, water)

Test Yourself

Test Yourself

A risk is a factor that will definitely happen and cause loss.

True

False

Test Yourself

Order the key steps in the risk analysis process:

- a. Estimate likelihood of exploitation
- b. Survey applicable controls and their costs
- c. Identify assets
- d. Compute expected annual loss
- e. Project annual savings of control
- f. Determine vulnerabilities

C, F, A, D, B, E

Test Yourself

List three risks in your home network system. Perform a basic risk analysis based on the above steps.

Test Yourself

Investigate the Boston University information security policy. Who wrote the policy? Who enforces the policy? Who does it cover? What resources does it cover?

Conclusion

In this module, we provide an overview of both technical and nontechnical aspects of cyber security. We first introduced the basic terminology and concepts in cybersecurity such as CIA, IAAA, privacy, vulnerabilities, threats, and risks. Then we discussed the legal and ethical aspects in cybersecurity. Finally we considered the management aspects of cybersecurity, in terms of security planning and risk analysis.

References

- Theohary, C. A., & Rollins, J. W. (2015). *Cyberwarfare and cyberterrorism: In brief*. Congressional Research Service.
- Pfleeger C. P., Pfleeger, S. L., & Marguiles, J. (2015). *Security in computing* (5th ed.). Prentice Hall.

Boston University Metropolitan College